

SGSI-UNCP

Marco de Referencia Terminológico y Normativo del SGSI-UNCP

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Control Documental
 - 1.1 Roles y Responsabilidades
 - 1.2 Distribución y Acceso
- 2 Propósito
 - 2.1 Obligatoriedad
- 3 Alcance
 - 3.1 Cobertura
 - 3.2 Exclusiones
- 4 Arquitectura Ontológica del SGSI-UNCP
 - 4.1 Modelo de Relaciones Semánticas
 - 4.2 Relaciones Jerárquicas Formales
 - 4.3 Taxonomía de Activos de Información
- 5 Niveles de Aplicación y Cumplimiento
 - 5.1 Modelo de Segregación por Perfil
 - 5.2 Matriz de Controles por Perfil
- 6 Diccionario Crítico Interoperable
 - 6.1 Términos Fundamentales
 - 6.2 Terminos Complementarios
- 7 Mapa de Referencias Normativas
 - 7.1 Jerarquía Normativa
 - 7.2 Normas Internacionales
 - 7.3 Normativa Nacional Peruana
 - 7.4 Normativa Interna UNCP
- 8 Matriz de Correspondencia entre Marcos Normativos
- 9 Vigencia, Revision y Mantenimiento
 - 9.1 Periodicidad de Revision
 - 9.2 Procedimiento de Actualizacion
 - 9.3 Indicadores de Eficacia
- 10 Anexos
 - 10.1 Anexo A: Abreviaturas y Acronimos
 - 10.2 Anexo B: Referencias Bibliograficas
- 11 Cierre

Organización: Universidad Nacional del Centro del Perú (UNCP)

Código del Documento: D-SGSI-00

Clasificación: Público Interno — Uso exclusivo del SGSI-UNCP

Normas Base: ISO/IEC 27000:2024, ISO/IEC 27001:2022, ISO/IEC 27002:2022, ISO 31000:2018, NIST SP 800-53 Rev. 5, NIST CSF 2.0, MITRE ATT&CK v14, MAGERIT v3

1. Control Documental

1.1. Roles y Responsabilidades

Rol	Responsabilidad	Cargo
Elaborador	Redactar y mantener el marco terminológico y el diccionario interoperable	Oficial de Seguridad y Confianza Digital
Revisor	Validar coherencia semántica, alineación normativa y aplicabilidad al contexto UNCP	Comité de Gobierno Digital (CGTD-UNCP)
Aprobador	Autorizar la entrada en vigor y asignar recursos para su implementación	Rectorado UNCP

1.2. Distribución y Acceso

Medio	Ubicación	Nivel de Acceso
Intranet institucional	uncp.edu.pe/sgsi/documentos	Público interno
Copia controlada impresa	Oficina de Gestión de la Calidad (SIGC)	Solo versión vigente

2. Propósito

El presente marco constituye el **léxico oficial** del Sistema de Gestión de Seguridad de la Información (SGSI) de la UNCP. Su propósito es triple:

Unificar el lenguaje entre los tres niveles organizacionales. El nivel estratégico (Alta Dirección, Rectorado) requiere comprender el riesgo en términos de impacto al negocio universitario. El nivel táctico (OTI, Planeamiento, Modernización) traduce los requisitos de seguridad en controles técnicos y procedimientos. El nivel operativo (Auditores, Docentes, Administrativos) ejecuta los controles y reporta incidentes bajo una nomenclatura común.

Mapear el ecosistema normativo que rige el SGSI-UNCP, estableciendo una jerarquía entre normas internacionales (ISO, NIST), nacionales (Ley 29733, D.L. 1412) e internas (Resoluciones, Directivas).

Eliminar ambigüedades en la interpretación de términos durante evaluaciones de riesgo, auditorías, comunicación de incidentes y redacción de políticas.

2.1. Obligatoriedad

Aspecto	Disposición
Alcance	Toda la documentación del SGSI-UNCP: políticas, procedimientos, instructivos, registros e informes
Desviación	No conformidad menor. Corrección en max. 30 días calendario
Fiscalización	Auditorías internas del SGSI

3. Alcance

3.1. Cobertura

Ámbito	Incluye
Activos de información	Los identificados en el Inventario de Activos (R-SGSI-02): sede Huancayo, Mantaro, Satipo y Tarma
Procesos y sistemas	Los que soportan la misión académica, administrativa y de investigación
Personal	Administrativo, docente, estudiantes, contratistas y terceros
Proveedores externos	Los que procesen, almacenen o transmitan datos UNCP (POL-SGSI-07)

3.2. Exclusiones

Exclusión	Motivo
Términos técnicos de infraestructura (configuraciones de red, comandos de SO)	Definidos en procedimientos operativos de la OTI
Jerga coloquial en comunicaciones informales	Fuera de la documentación formal del SGSI

4. Arquitectura Ontológica del SGSI-UNCP

4.1. Modelo de Relaciones Semánticas

La UNCP adopta una ontología dinámica donde los términos se relacionan jerárquicamente para facilitar el razonamiento de riesgo, siguiendo ISO/IEC 27000:2024 y extendiéndose con NIST CSF 2.0 y MITRE ATT&CK v14.

Componente	Descripción	Relación
Contexto Organizacional	Misión, partes interesadas, requisitos legales	Define el valor de los activos
Activo de Información	Personas, procesos, tecnología, instalaciones	Tiene valor, posee vulnerabilidades, requiere CID
Amenaza	Origen interno/externo, vector de ataque	Explota vulnerabilidades
Vulnerabilidad	CWE, CVE, debilidad de proceso	Es explotada por amenazas
Control	Preventivo, Detective, Correctivo, Recuperativo	Mitiga riesgos y protege activos

Componente	Descripción	Relación
Incidente	Impacta la CID, requiere respuesta NIST CSF	Se documenta en R-SGSI-04

4.2. Relaciones Jerárquicas Formales

Relación	Origen	Destino	Descripción
tiene_valor	ACTIVO	VALOR	Valor según criticidad definida en Metodología de Evaluación de Riesgos
posee_vulnerabilidad	ACTIVO	VULNERABILIDAD	El activo presenta debilidades explotables
explota	AMENAZA	VULNERABILIDAD	La amenaza usa una vulnerabilidad para materializar un incidente
materializa	AMENAZA + VULNERABILIDAD	INCIDENTE	Combinación que concreta un incidente de seguridad
impacta	INCIDENTE	CID	Afecta la Confidencialidad, Integridad y/o Disponibilidad
mitiga	CONTROL	RIESGO	Reduce la probabilidad y/o el impacto del riesgo
protege	CONTROL	ACTIVO	Salvaguarda el activo de información
se_alinea_con	CONTROL	NORMA	Implementa los requisitos de una norma específica
reporta_a	INCIDENTE	OFICIAL_SEGURIDAD	Todo incidente se reporta al Oficial de Seguridad

4.3. Taxonomía de Activos de Información

Clasificación según ISO/IEC 27002:2022 (Controles 5.9, 5.10, 5.13):

Categoría	Subcategoría	Ejemplos UNCP
Información	Digital	Bases de datos ADESA, registros de investigación, resoluciones rectorales
Información	Física	Expedientes estudiantiles, libros de actas, contratos, convenios
Software	Misional	ADESA, GESDOC, SIGA, Moodle, Repositorio DSpace
Software	Soporte	Microsoft 365, MyLOFT, Turnitin, CTI Vitae
Hardware	Servidores	Físicos y virtuales en Data Center Huancayo

Categoría	Subcategoría	Ejemplos UNCP
Hardware	Estaciones	Equipos de escritorio y portátiles de personal
Hardware	Red	Switches, routers, firewalls, APs Wi-Fi (4 sedes)
Personas	Interno	Autoridades, docentes, administrativos, OTI
Personas	Terceros	Proveedores cloud, contratistas de mantenimiento
Servicios	Digitales	Correo, portal web, matrícula en línea, mesa de partes
Servicios	Físicos	Data center, centros de computo, laboratorios
Instalaciones	Infraestructura	Data center principal, cuartos de comunicaciones

5. Niveles de Aplicación y Cumplimiento

5.1. Modelo de Segregación por Perfil

Nivel	Población	Fundamento	Acciones	Consecuencias
I — Mandatorio	Administrativos y Docentes	Acceso a sistemas críticos (ADESA, SIGA, GESDOC, M365) y datos personales (Ley 29733)	POL-SGSI-05, Acuerdo Conf., 4h/año capacitación, MFA obligatorio	Leves: amonestación. Graves: susp. acceso + DGA. Críticas: OCI + legal
II — Concientización	Estudiantes	Sin control sobre dispositivos personales. Riesgo gestionado via educación	Campañas, módulo inducción 2h, Guía de BDP	Bienestar Univ. y Defensoría, sin sanciones técnicas

5.2. Matriz de Controles por Perfil

Control	Alta Dirección	Personal Admin.	Docentes	Estudiantes	Proveedores
POL-SGSI-01 (Desarrollo Seguro)	Aplica	Parcial	Aplica	No aplica	Aplica
POL-SGSI-02 (Control de Acceso)	Aplica	Aplica	Aplica	Parcial	Aplica
POL-SGSI-03 (Clasificación)	Aplica	Aplica	Aplica	Concientización	Aplica
POL-SGSI-04 (Incidentes)	Aplica	Aplica	Aplica	Reporta	Aplica
POL-SGSI-05 (Uso Aceptable TIC)	Aplica	Aplica	Aplica	Concientización	Aplica
POL-SGSI-06 (Continuidad)	Aplica	Parcial	Parcial	Concientización	Parcial
POL-SGSI-07 (Proveedores)	Aplica	Parcial	Parcial	No aplica	Aplica

Control	Alta Dirección	Personal Admin.	Docentes	Estudiantes	Proveedores
POL-SGSI-08 (Cifrado y Claves)	Aplica	Aplica	Aplica	Concientización	Aplica

6. Diccionario Crítico Interoperable

Correspondencia entre ISO/IEC 27000, NIST SP 800-53, MITRE ATT&CK v14 y MAGERIT v3.

6.1. Términos Fundamentales

6.1.1. Activo de Información

Atributo	Descripción
Definicion ISO 27000	Cualquier cosa que tiene valor para la organizacion
Definicion UNCP	Recurso (informacion, software, hardware, personas, servicios, instalaciones) necesario para la mision universitaria
Clasificacion UNCP	Critico / Alto / Medio / Bajo
NIST	Asset (FAM: Asset Management)
MAGERIT	Activo (dimensiones: D, S, SW, HW, COM, AUX, L, P)
Ejemplo UNCP	Base de datos de estudiantes en ADESA (Critico). Portal web (Alto)

6.1.2. Amenaza

Atributo	Descripción
Definicion ISO 27000	Causa potencial de un incidente no deseado
Origen	Interna (personal, procesos) / Externa (ciberdelincuentes, desastres, proveedores)
Clasificacion UNCP	Natural / Humana intencional / Humana no intencional / Tecnologica / Fisica
MITRE	Threat Actor / Campaign (T1566 Phishing, T1190 Exploit)
MAGERIT	Amenaza (catalogo: N, I, P, A)
Ejemplo UNCP	Phishing dirigido a docentes con marca UNCP. Falla electrica en Data Center

6.1.3. Vulnerabilidad

Atributo	Descripción
Definicion ISO 27000	Debilidad de un activo o control explotable por una o mas amenazas
NIST	Weakness (CWE) / Vulnerability (CVE)
MAGERIT	Debilidad en la salvaguarda

Atributo	Descripción
Ejemplo UNCP	Servidor Moodle sin parche. Red sin segmentación entre laboratorios y servidores. OTI: 2 personas para 17 sistemas

6.1.4. Riesgo

Atributo	Descripción
Definición ISO 27000	Efecto de la incertidumbre sobre los objetivos
Definición ISO 31000	Probabilidad x Impacto
Fórmula UNCP	Riesgo = Probabilidad de materialización x Impacto en CID
Niveles UNCP	Muy Alto (15-25) / Alto (10-14) / Medio (5-9) / Bajo (1-4)
NIST	Risk (SP 800-30 Rev. 1)
Ejemplo UNCP	Filtración de datos de 20,000 estudiantes por falta de cifrado en ADESA. Multas hasta 30 UIT

6.1.5. Control / Salvaguarda

Atributo	Descripción
Definición ISO 27000	Medida que modifica el riesgo
Tipos	Preventivo / Detective / Correctivo / Disuasivo / Recuperativo
Naturaleza	Admin. (políticas) / Técnico (firewall, MFA) / Físico (CCTV, cerraduras)
NIST	Security Control (SP 800-53: Low, Moderate, High)
ISO 27001	A.5 (organizacionales) / A.6 (personas) / A.7 (físicos) / A.8 (tecnológicos)
Ejemplo UNCP	A.5.15: MFA para ADESA (Preventivo, Técnico). A.7.8: CCTV en Data Center (Detective, Físico)

6.1.6. Incidente de Seguridad

Atributo	Descripción
Definición ISO 27000	Evento con probabilidad de comprometer operaciones y seguridad de la información
Clasificación UNCP	Incidente de Confidencialidad / Integridad / Disponibilidad
NIST CSF 2.0	Detect (DE) / Respond (RS) / Recover (RC)
Ejemplo UNCP	Caída de matrícula en línea (Disponibilidad). Acceso no autorizado a correo docente (Confidencialidad). Modificación de notas en ADESA (Integridad)

6.1.7. CID (Confidencialidad, Integridad, Disponibilidad)

Atributo	Confidencialidad	Integridad	Disponibilidad
Definicion ISO 27000	Informacion no revelada a no autorizados	Exactitud y completez de los activos	Accesible y utilizable a demanda
Pregunta de auditoria	Quien puede acceder	Esta completa y es correcta	Esta disponible cuando se necesita
Ejemplo UNCP	Notas solo para docentes autorizados y Admision	Registros de investigacion con control de versiones	Portal de matricula 24/7 en periodo de admision

6.2. Terminos Complementarios

Termino	Definicion UNCP	Marco
Analisis de Riesgos	Identificacion de amenazas y vulnerabilidades, estimacion de probabilidad e impacto	ISO 31000, MAGERIT v3
Tratamiento de Riesgos	Seleccion de medidas para modificar el riesgo (Reducir, Retener, Evitar, Transferir)	ISO 27001 (Clausula 6.2)
Declaracion de Aplicabilidad (SoA)	Lista de controles del Anexo A con justificacion de inclusion/exclusion	ISO 27001 (Clausula 6.1.3 d)
Plan de Tratamiento	Acciones, recursos, responsables y plazos para implementar controles	ISO 27001 (Clausula 6.2)
Auditoria Interna	Proceso independiente y documentado para evaluar el cumplimiento del SGSI	ISO 27001 (Clausula 9.2)
No Conformidad	Incumplimiento de un requisito del SGSI (Mayor o Menor)	ISO 27001 (Clausula 10.1)
KPI	Métrica cuantificable de eficacia de controles (ej.: % sistemas con parches al día)	ISO 27001 (Clausula 9.1)
Parte Interesada	Entidad que afecta o es afectada por el SGSI (SUNEDU, OCI, MINEDU, estudiantes)	ISO 27001 (Clausula 4.2)
Contexto Organizacional	Entorno interno y externo de la UNCP	ISO 27001 (Clausula 4.1)

7. Mapa de Referencias Normativas

7.1. Jerarquia Normativa

Nivel	Marco	Ejemplos
1 — Internacional	ISO, NIST	ISO/IEC 27001:2022, NIST CSF 2.0, MITRE ATT&CK v14
2 — Nacional Peruano	Leyes, Decretos, Resoluciones	Ley 29733, D.L. 1412, D.S. 029-2021-PCM
3 — Sectorial	SUNEDU, MINEDU	Ley Universitaria 30220, Modelo de Licenciamiento

Nivel	Marco	Ejemplos
4 — Interno UNCP	Resoluciones, Directivas, Planes	PGTD 2026-2030, PEI, ROF, MOF
5 — Documentacion SGSI	Políticas, Procedimientos, Registros	POL-SGSI-01 a 08, M-SGSI-01, R-SGSI-02 a 04

7.2. Normas Internacionales

Norma	Componente	Aplicacion en UNCP
ISO/IEC 27001:2022	Clausulas 4 a 10 (requisitos auditables)	Base para diseno, implementacion y certificacion del SGSI-UNCP
ISO/IEC 27001:2022	Anexo A (93 controles en A.5, A.6, A.7, A.8)	Base para la SoA y seleccion de controles
ISO/IEC 27002:2022	Guia de implementacion de controles	Referencia tecnica para diseno de controles
ISO 31000:2018	Principios y proceso de gestion del riesgo	Integracion con el Sistema de Control Interno (SCI)
NIST CSF 2.0	Govern, Identify, Protect, Detect, Respond, Recover	Alineacion del SGSI con el PGTD 2026-2030
MITRE ATT&CK v14	Tacticas, Tecnicas, Procedimientos	Modelado de amenazas y reglas de deteccion en SIEM
MAGERIT v3	Catalogo de elementos y procedimientos	Valoracion de activos en el sector publico

7.3. Normativa Nacional Peruana

Norma	Componente	Implicancia para el SGSI-UNCP
Ley N° 29733	Art. 3 (Principios), Art. 9 (Seguridad)	Controles de acceso, cifrado e incidentes sobre bases de datos con datos personales
D.S. N° 016-2024-JUS	Exige DPIA para tratamientos de alto riesgo	Realizar DPIAs antes de nuevos sistemas con datos personales a gran escala
D.L. N° 1412	Art. 4, 13 (Confianza Digital), 17 (Interoperabilidad)	SGSI demuestra seguridad digital. Sistemas PIDE deben cumplir Directiva 001-2025-PCM/SGTD
D.S. N° 029-2021-PCM	Designacion del Oficial de Seguridad	Brecha: UNCP no ha designado este rol. Accion prioritaria
D.S. N° 141-2025-PCM	Quinta Disposicion: uso intensivo de tecnologias digitales	SGSI como habilitador de tecnologia digital segura
Ley Universitaria 30220	Autonomia, licenciamiento, calidad educativa	SGSI contribuye a CBC 6 (Infraestructura) y CBC 7 (Gestion de calidad)
D.S. N° 051-2018-PCM	1 % de presupuesto TI para software público	UNCP debe priorizar software público en adquisiciones y desarrollo
R.M. N° 119-2024-PCM	Lineamientos de Transformación Digital	Establece obligaciones de seguridad digital para todas las entidades del Estado

Norma	Componente	Implicancia para el SGSI-UNCP
D.L. N° 1646	Ciberseguridad y confianza digital	Define el marco de ciberseguridad nacional aplicable a universidades públicas
Ley N° 31814	Ley de Ciberseguridad	Exige implementación de controles mínimos de seguridad en infraestructura crítica

7.4. Normativa Interna UNCP

Documento	Año	Relacion con el SGSI
PGTD 2026-2030	2026	Define el proyecto PGTD-01 (SGSI) con presupuesto de S/ 850,000
PEI 2024-2030	2024	Objetivos estrategicos que el SGSI apoya mediante gestion de riesgos
Plan de Continuidad Operativa	2026	Procedimientos de continuidad complementados con controles A.5.29 y A.5.30
Mapa de Procesos Nivel 0 y 01	2025	Identifica procesos criticos a proteger
Directiva de Correo Electronico	2022	Primer documento formal de seguridad. Integrado en POL-SGSI-05
ROF, MOF, CAP, PAP	2014-2025	Unidades y cargos responsables de seguridad de la informacion

8. Matriz de Correspondencia entre Marcos Normativos

Concepto	ISO 27001:2022	NIST CSF 2.0	NIST SP 800-53	MITRE ATT&CK
Activo	A.5.9	ID.AM	CM-8	T1583 (Adquisición de Infraestructura)
Riesgo	Clausula 6.1	GV.RM	RA-3	No equivalente directo
Amenaza	A.5.7	ID.RA	RA-3, SI-4	Tactic / Technique
Vulnerabilidad	A.8.8	ID.RA	RA-5	CVE / CWE
Control de Acceso	A.5.15, A.5.16, A.5.18, A.8.2, A.8.3, A.8.5	PR.AA	AC-1 a AC-25	TA0001 (Persistencia)
Concientizacion	A.6.3	PR.AT	AT-2, AT-3	T1566 (Phishing)
Respuesta a Incidentes	A.5.24, A.5.25, A.5.26	RS.MA	IR-4 a IR-7	T1078 (Cuentas Válidas) / T1059 (Ejecución)
Continuidad del Negocio	A.5.29, A.5.30	RC.RP	CP-2, CP-10	T1490 (Denegación de Servicio) / T1485 (Destrucción)
Cifrado	A.5.32, A.8.11, A.8.24	PR.DS	SC-8, SC-13	TA0010 (Exfiltración)

9. Vigencia, Revision y Mantenimiento

9.1. Periodicidad de Revision

Tipo	Periodicidad	Responsable	Disparador
Programada	Anual (enero)	Oficial de Seguridad	Calendario de revisiones del SGSI
Extraordinaria	Cuando ocurra un cambio significativo	Oficial de Seguridad	Nueva normativa nacional, actualizacion ISO 27001, incidente critico
Sincronizacion MITRE/NIST	Semestral (julio y enero)	Oficial de Seguridad + OTI	Nueva version de MITRE ATT&CK o NIST SP 800-53

9.2. Procedimiento de Actualizacion

Fase	Accion	Responsable
1. Deteccion	Monitorear ISO OBP, IEC Electropedia, Portal PCM, El Peruano, MITRE Releases, NIST News	Oficial de Seguridad
2. Evaluacion	Determinar si el cambio requiere modificacion, adicion o eliminacion de terminos	Oficial de Seguridad
3. Actualizacion	Elaborar nueva version segun control documental (Seccion 1)	Oficial de Seguridad
4. Comunicacion	Notificar al CGTD, publicar en repositorio, emitir boletin si el cambio es critico	Oficial de Seguridad
5. Registro	Actualizar historial y conservar version anterior en archivo	Oficial de Seguridad

9.3. Indicadores de Eficacia

KPI	Formula	Meta	Frecuencia
Documentos sin desviaciones terminologicas	$(\text{Conformes} / \text{Total}) \times 100$	$\geq 95 \%$	Trimestral
Tiempo de incorporacion de nuevos terminos	Dias desde publicacion de norma hasta actualizacion	≤ 30 dias	Por evento
Personal que comprende terminos criticos	$(\text{Calificacion} \geq 80 \% / \text{Total evaluado}) \times 100$	$\geq 90 \%$	Anual

10. Anexos

10.1. Anexo A: Abreviaturas y Acronimos

Abreviatura	Significado
CID	Confidencialidad, Integridad, Disponibilidad
CGTD	Comite de Gobierno Digital
DGA	Direccion General de Administracion
DPIA	Data Protection Impact Assessment
MFA	Autenticacion Multifactor
OCI	Organo de Control Institucional
OTI	Oficina de Tecnologias de la Informacion
PGTD	Plan de Gobierno y Transformacion Digital
PIDE	Plataforma de Interoperabilidad del Estado
SCI	Sistema de Control Interno
SGSI	Sistema de Gestion de Seguridad de la Informacion
SGTD	Secretaria de Gobierno y Transformacion Digital
SIEM	Security Information and Event Management
SIGC	Sistema Integrado de Gestion de la Calidad
SoA	Statement of Applicability
UIT	Unidad Impositiva Tributaria

10.2. Anexo B: Referencias Bibliograficas

Codigo	Referencia
ISO 27000	ISO/IEC 27000:2024 — Overview and vocabulary
ISO 27001	ISO/IEC 27001:2022 — Requirements
ISO 27002	ISO/IEC 27002:2022 — Information security controls
ISO 31000	ISO 31000:2018 — Risk management guidelines
NIST SP 800-53	NIST SP 800-53 Rev. 5
NIST CSF 2.0	NIST Cybersecurity Framework 2.0
MITRE ATT&CK	MITRE ATT&CK v14
MAGERIT	MAGERIT v3 — Metodologia de Analisis y Gestion de Riesgos
Ley 29733	Ley de Proteccion de Datos Personales
D.S. 016-2024-JUS	Reglamento de la Ley 29733
D.L. 1412	Decreto Legislativo de Gobierno Digital

11. Cierre

El presente Marco de Referencia Terminologico y Normativo (D-SGSI-00) constituye la base documental fundamental del SGSI-UNCP. Todos los documentos del sistema deben alinearse a las definiciones, clasificaciones y jerarquias aqui establecidas. El incumplimiento de esta directriz sera tratado como una no conformidad en las auditorias internas del SGSI.

La version vigente de este documento se encuentra en el repositorio documental del SGSI. Se debe verificar que se esta utilizando la version correcta antes de referenciarlo.